

HOR-REG-201 — Marco Regulatorio CNBV Aplicable a la Operación Tecnológica

Banco Horizonte, S.A., Institución de Banca Múltiple

Versión 5.1 · Vigencia desde 2026-02-28 · Clasificación: Uso Interno

Propietario: Enlace CNBV (RG-CNBV) · Aprobado por: Comité de Riesgos

1. Objeto

Este documento traduce las obligaciones regulatorias de la Comisión Nacional Bancaria y de Valores (CNBV) en materia de riesgo operacional, riesgo tecnológico y seguridad de la información, a responsabilidades concretas dentro de Banco Horizonte. No sustituye a la norma: la fuente obligatoria son las Disposiciones de carácter general aplicables a las instituciones de crédito (conocidas como CUB o Circular Única de Bancos) y sus anexos, publicadas en el Diario Oficial de la Federación.

2. Marco normativo de referencia

Los instrumentos que rigen la operación tecnológica de la institución son, principalmente:

- **Circular Única de Bancos (CUB).** Disposiciones de carácter general aplicables a las instituciones de crédito, emitidas por la CNBV. Contiene el título de administración integral de riesgos y el capítulo de uso de servicios de banca electrónica e infraestructura tecnológica.
- **Anexo 12-A de la CUB.** Riesgo operacional. Define la clasificación de tipos de evento y las consideraciones para la base de datos histórica de eventos de pérdida. Establece que las pérdidas de un evento, o de varios eventos relacionados a lo largo del tiempo, registradas contablemente en varios años, se asignan a los años que les corresponden. También obliga a identificar y registrar las **cuasi-pérdidas**, entendidas como eventos que no conducen a pérdida o cuya pérdida se recupera en corto plazo.
- **Anexo 1-D Bis de la CUB.** Marco para la administración integral de riesgos, inventario de procesos, riesgos operacionales, controles y planes de mitigación, e inventario de indicadores clave de riesgo operacional.
- **Anexo 52 de la CUB.** Lineamientos mínimos de operación y seguridad para la contratación de servicios de apoyo tecnológico con terceros.
- **Anexo 64 Bis de la CUB.** Informe de incidentes de seguridad de la información.
- **Anexo 71 de la CUB.** Requerimientos técnicos para la captura de huellas dactilares e identificación facial como datos biométricos.
- **Anexo 72 de la CUB.** Indicadores de seguridad de la información. Establece indicadores clave de riesgo y de desempeño, organizados por tipos de evento (entre ellos fraude interno y fraude externo) con subtipos y subclases, con periodicidad y umbrales definidos. La norma asigna al responsable jerárquico de seguridad de la información la evaluación, definición de planes y mantenimiento de los indicadores.
- **Reportes regulatorios serie R28.** Información de riesgo operacional, con subreportes que incluyen eventos de pérdida por riesgo operacional, su actualización, la estimación de niveles de riesgo operacional y la asignación por el método del indicador de negocio. Se envían a través del Sistema Interinstitucional de Transferencia de Información (SITI).
- **Plan Director de Seguridad.** Figura prevista en la normativa vigente desde la reforma de 2018, orientada a reducir la exposición a riesgos tecnológicos y la materialización de incidentes de seguridad de la información hasta niveles aceptables, conforme a lo que defina el Consejo de Administración. El director general debe

informar su contenido al Consejo.

Nota de uso interno. Las referencias a artículos concretos de la CUB cambian con cada reforma publicada en el DOF. El Enlace CNBV mantiene la tabla de correspondencia actualizada en el expediente HOR-REG-201-A y la valida trimestralmente contra la versión vigente publicada por la Comisión. No debe citarse un número de artículo sin validar contra esa tabla.

3. Obligaciones operativas derivadas

3.1 Base de datos histórica de eventos de pérdida

Banco Horizonte mantiene una base de datos histórica de eventos de pérdida por riesgo operacional administrada por Riesgos No Financieros. Campos mínimos capturados por evento:

Campo	Fuente en Banco Horizonte
Identificador del evento	Ticket INC o PRB del ITSM
Fecha de ocurrencia	Hora del primer síntoma verificable
Fecha de descubrimiento	Hora de detección registrada por el Command Center
Fecha de registro contable	Contraloría
Línea de negocio afectada	Catálogo interno alineado a líneas regulatorias
Tipo y subtipo de evento	Clasificación del Anexo 12-A
Riesgo asociado	Tecnológico, legal, de crédito, de mercado u operacional puro
Monto bruto de pérdida	Contraloría y Jurídico
Montos recuperados	Seguros, proveedores, recuperaciones directas
Descripción breve	Extracto del postmortem
Cuasi-pérdida (sí/no)	Dictamen de Riesgos No Financieros

Regla interna: todo incidente P1 y P2 genera un registro candidato en esta base dentro de los 5 días hábiles siguientes al cierre. La ausencia de pérdida económica no exime del registro.

3.2 Inventario de riesgos y controles

El inventario de procesos, riesgos operacionales, controles y planes de mitigación se actualiza semestralmente. Cada servicio del catálogo crítico (documento HOR-OPS-002) debe tener al menos: un riesgo identificado, un control asociado, un responsable del control y evidencia de su operación efectiva.

3.3 Indicadores de seguridad de la información

La institución mantiene indicadores alineados a la estructura del Anexo 72, con periodicidad mensual o trimestral según el indicador, y con umbrales de semáforo. Ejemplos operados por el área de Ciberseguridad:

Indicador	Naturaleza	Periodicidad	Umbral rojo	Umbral verde
Incidentes de seguridad atribuidos a vulnerabilidades en sistemas provistos por terceros, respecto al total	Reactivo	Mensual	Más de 5%	Menos de 0.1%
Incidentes con pérdida pecuniaria respecto al total	Correctivo	Trimestral	Más de 3%	Menos de 1%
Vulnerabilidades críticas no remediadas en plazo	Correctivo	Mensual	Más de 5%	Menos de 2%

Indicador	Naturaleza	Periodicidad	Umbral rojo	Umbral verde
Accesos privilegiados sin revisión periódica	Preventivo	Trimestral	Más de 5%	Menos de 2%

Los valores de umbral mostrados siguen la lógica de bandas de la norma; la calibración exacta de cada indicador se documenta en el expediente del Plan Director de Seguridad.

3.4 Informe de incidentes de seguridad de la información

Cuando un incidente cumple los criterios de la normativa para ser informado a la Comisión, el flujo interno es:

1. Ciberseguridad emite dictamen técnico preliminar (máximo 4 horas desde la detección).
2. Riesgos No Financieros valida el alcance y la clasificación.
3. Jurídico revisa implicaciones.
4. El Enlace CNBV integra y presenta el informe conforme al formato y plazos aplicables.
5. Se conserva el expediente completo (evidencia técnica, cronología del Scribe, comunicaciones) por cinco años.

Ningún área puede comunicarse directamente con la Comisión sin el Enlace CNBV. Esta regla no admite excepción por urgencia.

3.5 Servicios de apoyo tecnológico (terceros)

Todo proveedor que opere o tenga acceso a infraestructura tecnológica relevante se registra en el inventario de terceros críticos y debe cumplir los lineamientos mínimos de operación y seguridad aplicables a la contratación de servicios de apoyo tecnológico. Requisitos internos adicionales:

- Cláusula de derecho de auditoría por la institución y por la autoridad.
- Definición contractual de niveles de servicio y penalizaciones.
- Plan de salida documentado y probado (exit plan).
- Notificación obligatoria al banco de cualquier incidente que afecte al servicio contratado, en un plazo máximo de 2 horas.
- Evaluación anual de riesgo del proveedor, con revisión extraordinaria si presenta un incidente crítico.

4. Calendario regulatorio interno

Obligación	Periodicidad	Área responsable	Plazo interno
Reportes serie R28 (eventos de pérdida y actualización)	Trimestral	Riesgos No Financieros	10 días hábiles antes del vencimiento oficial
Estimación de niveles de riesgo operacional	Trimestral	Riesgos No Financieros	10 días hábiles antes
Indicadores de seguridad de la información	Mensual / trimestral	Ciberseguridad	Día 10 del mes siguiente
Actualización del inventario de riesgos y controles	Semestral	Riesgos No Financieros	Junio y diciembre
Informe del Plan Director de Seguridad al Consejo	Anual	CISO	Sesión de enero
Pruebas de continuidad de negocio	Semestral	Continuidad	Marzo y septiembre
Evaluación de terceros críticos	Anual	Riesgo de Terceros	Cierre de octubre

5. Puntos de fricción conocidos

Documentados por Auditoría Interna en la revisión AI-2026-07:

1. **Desfase entre el cierre operativo del incidente y su registro como evento de pérdida.** Promedio observado: 11 días hábiles contra los 5 establecidos internamente.
2. **Calidad de la descripción del evento.** El 22% de los registros de 2025 contienen descripciones que no permiten reconstruir el evento sin consultar el ticket original.
3. **Cuasi-pérdidas subregistradas.** Se estima que se registra menos del 40% de las cuasi-pérdidas efectivamente ocurridas, porque los equipos técnicos las perciben como "incidentes sin consecuencia".
4. **Trazabilidad de terceros.** Tres proveedores relevantes no tienen documentado el plan de salida probado.

Las cuatro observaciones tienen plan de remediación con fecha compromiso a diciembre de 2026.